

Cloud Security Policy

Asteria Digital Services | CSP-SEC-004 | Version 3.0 | Effective 2026-05-20

Owner: Information Security

Synthetic training document - created for the Week 2 RAG project. No real company policy is represented.

1. Purpose and Applicability

This policy establishes mandatory controls for workloads and data hosted in public cloud or cloud-managed services used by Asteria Digital Services.

2. Identity and Access

- Human administrative access **MUST** use multi-factor authentication (MFA).
- Access **MUST** follow least privilege and role-based access control (RBAC).
- Shared administrator accounts are prohibited except for documented emergency break-glass accounts.
- Workloads **SHOULD** use managed identity, workload identity, or short-lived credentials instead of long-lived static secrets.

3. Secrets

- Passwords, API keys, private keys, client secrets, and tokens **MUST** be stored in an approved secrets-management service.
- Secrets **MUST NOT** be hard-coded in source code, container images, CI/CD variables visible to unauthorized users, or plain-text configuration files.
- Secrets **SHOULD** be rotated automatically where the platform supports rotation.

4. Encryption

- External and inter-service network communication carrying company data **MUST** use TLS 1.2 or higher.
- Confidential and Restricted data **MUST** be encrypted at rest using platform-managed or approved customer-managed keys.
- Restricted data **SHOULD** use customer-managed keys when required by regulation, contractual commitment, or the system risk assessment.
- Public information does not require encryption at rest unless the hosting platform enforces it by default.

5. Network Exposure

- Internet exposure **MUST** be explicitly justified and reviewed.

- Administrative interfaces SHOULD use private connectivity or trusted access paths and MUST NOT be openly exposed to the internet without compensating controls.
- Inbound rules SHOULD follow deny-by-default principles and allow only required protocols, ports, and sources.

6. API and Application Security

Internet-facing APIs must follow ADS-API-STD-001, including OAuth 2.0 or OIDC and TLS 1.2+. Application logs must follow LMS-OPS-003. Restricted information must not be written to normal logs.

7. Security Events

- Repeated failed privileged logins, unexpected public exposure, suspected secret leakage, and access from prohibited locations SHOULD generate security alerts.
- Suspected compromise of credentials or Restricted data requires immediate incident handling under the Incident Management Guide.

8. Minimum Control Summary

Topic	Standard
Admin access	MFA + least privilege
Secrets	Approved secrets manager; never hard-code
Transport	TLS 1.2+
Confidential/Restricted at rest	Encryption required
Restricted data in normal logs	Prohibited